

Informe SOC2.

Actúas como el orquestador principal de un consorcio de los mejores CISOs del mundo, criptógrafos cuánticos, arquitectos de Zero Trust, teóricos del riesgo actuarial, Estrategas de ciberseguridad, resiliencia digital y continuidad de negocios de Clase Mundial junto con expertos internacionales con más de 15 años de experiencia en investigación de vanguardia, filosofía de la ciencia, edición en revistas de alto impacto.

Tu misión es ejecutar una investigación exhaustiva, sin límite de palabras, sobre las últimas tendencias (desde 2025) en indicadores del marco SOC2 (System and Organization Controls 2). Enfócate en los indicadores y las métricas de ciberseguridad propuestas por SOC2 con aplicación a nivel nacional territorial para España, pero con un enfoque comparativo mundial.

Utiliza exclusivamente fuentes fiables y de alta calidad, como:

- artículos académicos revisados por pares
- organismos oficiales y gubernamentales
- universidades y centros de investigación reconocidos
- instituciones educativas y científicas de prestigio
- documentación oficial del fabricante, desarrollador o creador de la tecnología (cuando el tema investigado sea una tecnología o herramienta específica).
- Informes industriales y documentación técnica.

Descarta blogs personales, foros, contenido opinativo, marketing no técnico y fuentes sin autor.

Cuida el lenguaje español, afinando con cuidado y esmero en las listas o viñetas de posibles respuestas ad hoc a las preguntas inquisitivas de la encuesta. Que sea ameno, abierto y con el tono irónico y literario que supone una acción propositiva y constructiva.

SOC 2 no define un “catálogo oficial de indicadores”, pero desde 2022–2026 se ha ido consolidando, de facto, un conjunto de métricas ligadas a los Criterios de Servicios de Confianza (Trust Services Criteria, TSC) que los auditores exigen cada vez con más rigor, y que encajan casi quirúrgicamente con ENS, RGPD y NIS2 en España.¹²³⁴⁵

A continuación tienes: (1) marco conceptual mínimo, (2) indicadores y métricas avanzadas por criterio SOC 2, (3) lectura en clave España (ENS + NIS2 + CNCS), y (4) ejemplos de cómo “traducir” esos indicadores a una encuesta nacional para organizaciones españolas.

1 <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

2 <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

3 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

4 <https://www.flexxible.com/en/blog/nis2-directive-spain>

5 <https://www.konfirmity.com/blog/soc-2-what-changed-in-2026>

1. Marco SOC 2 2025–2026 en una frase larga

SOC 2 es un examen de atestación sobre controles de una organización de servicios relevantes para seguridad, disponibilidad, integridad del procesamiento, confidencialidad y privacidad, definido por el AICPA a través de los Trust Services Criteria de 2017, cuyos puntos de enfoque se actualizaron en 2022 sin cambiar los criterios de fondo.⁶⁷⁸⁹

La práctica global converge en usar siempre el criterio de **seguridad** (Common Criteria CC1–CC9) y añadir selectivamente disponibilidad, integridad de procesamiento, confidencialidad y privacidad en función del modelo de negocio y la presión regulatoria (sanitario, financiero, cloud crítico, etc.).¹⁰¹¹¹²¹³

2. Common Criteria (Seguridad): indicadores “duros”

Los nueve Common Criteria de seguridad constituyen la espina dorsal, y desde 2022 los auditores están pidiendo más trazabilidad, automatización y vínculo explícito con riesgos emergentes (cloud, IA, trabajo remoto, ataques acelerados).¹⁴¹⁵¹⁶¹⁷¹⁸

6 <https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2>

7 <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

8 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

9 <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

10 <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

11 <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

12 <https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2>

13 <https://secureframe.com/hub/soc-2/trust-services-criteria>

14 <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

15 <https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2>

16 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

17 <https://secureframe.com/hub/soc-2/trust-services-criteria>

18 <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

2.1 CC1 – Entorno de control (gobierno, ética, tono desde la cúpula)

Tendencia global: pasar del “tenemos políticas” al “podemos probar que la dirección toma decisiones basadas en riesgo y métricas”, alineado con expectativas reforzadas de supervisores europeos bajo NIS2.¹⁹²⁰²¹²²

Indicadores típicos y maduros:

- Porcentaje de objetivos de ciberseguridad aprobados en órgano de gobierno (Consejo, Comisión de Riesgos) con metas cuantificadas (ej. reducción del tiempo de detección de incidentes críticos $\geq X$ % anual).⁴⁵
- Frecuencia de revisión formal del marco de riesgos de seguridad y privacidad (mínimo anual, tendencia semestral).
- Porcentaje de decisiones de inversión en seguridad respaldadas por análisis de riesgo documentado (NIS2 empuja explícitamente hacia gobernanza basada en riesgo, lo que los auditores usan como munición moral).⁵⁴
- Evidencias de segregación de funciones en gobernanza (CISO independiente, reporting dual a Dirección y Consejo, etc.).

Ejemplo de pregunta de encuesta (tono irónico-constructivo):

- “Cuando su comité de dirección habla de ciberseguridad, ¿maneja indicadores cuantitativos o se limita al ancestral arte de las diapositivas tranquilizadoras?”

2.2 CC2 – Información y comunicación

Se exige demostrar que la información de riesgos, incidentes y cambios llega a quien debe decidir, en tiempo y forma.²³²⁴²⁵

Indicadores clave:

19 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

20 <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

21 <https://www.konfirmity.com/blog/soc-2-what-changed-in-2026>

22 <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

23 <https://secureframe.com/hub/soc-2/trust-services-criteria>

24 <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

25 <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

- Porcentaje de políticas de seguridad y privacidad comunicadas y con lectura aceptada por los empleados (con evidencia en HR/IT).
- Tiempo medio entre la detección de un incidente mayor y la notificación interna a los órganos de gobierno definidos (incluida la cadena NIS2/ENS donde aplique).¹⁰⁴
- Cobertura de formación en seguridad: % de plantilla con formación anual específica según rol; % con formación reforzada en IA generativa, ingeniería social avanzada, etc.

Pregunta posible:

- “¿Cada cuánto recibe la alta dirección informes con métricas de ciberseguridad?
A) Cuando pasa algo malo.
B) Trimestralmente.
C) Mensualmente y con datos comparables.
D) Lo llamamos “panel continuo” y asusta menos que la cuenta de resultados.”
- A) Cuando pasa algo malo.
• B) Trimestralmente.
• C) Mensualmente y con datos comparables.
• D) Lo llamamos “panel continuo” y asusta menos que la cuenta de resultados.”

2.3 CC3 – Evaluación de riesgos

Los criterios SOC 2 insisten en un proceso formal continuo de identificación, análisis y respuesta a riesgos, ampliado en 2022 para incluir tecnologías emergentes (cloud multi-proveedor, IA, automatización).²⁶²⁷²⁸²⁹

Indicadores sugeridos:

- Porcentaje de activos y servicios críticos con análisis de riesgos actualizado en los últimos 12 meses (para operadores NIS2, el 100% es ya una expectativa social, si no legal).⁴⁵
- Número de riesgos críticos de seguridad sin plan de tratamiento aprobado y con hitos temporales definidos.
- Porcentaje de proyectos relevantes (cloud, IA, outsourcing) con evaluación de impacto en protección de datos y ciberseguridad antes de su aprobación (PIA/DPIA donde corresponda).

Pregunta-anzuelo:

²⁶ <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

²⁷ <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

²⁸ <https://secureframe.com/hub/soc-2/trust-services-criteria>

²⁹ <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

- “Cuando se aprueba un nuevo proyecto cloud/IA, ¿el análisis de riesgo llega antes, durante o después de la firma del contrato (o nunca confesaremos)?”

2.4 CC4 – Actividades de monitoreo

Aquí se observa la mayor presión post-2024: se espera evidencia de monitorización continua, uso de telemetría avanzada y, en muchos casos, de SOC maduro, alineado con los requisitos de detección temprana de NIS2.³⁰³¹³²³³

Indicadores:

- Porcentaje de sistemas críticos bajo monitorización continua (EDR/XDR, SIEM, NDR).
- Mean Time To Detect (MTTD) y Mean Time To Respond (MTTR) para incidentes de severidad alta.
- Porcentaje de alertas de alta criticidad analizadas dentro de plazos objetivo (por ejemplo, 1 hora para alta, 24 horas para media).

Pregunta:

- “¿Su organización mide el tiempo medio de detección y respuesta, o confía en la milenaria métrica de ‘lo supimos cuando ya estaba en la prensa’?”

2.5 CC5 – Actividades de control

Los auditores buscan coherencia entre políticas, procedimientos y controles automatizados, especialmente en accesos, cambios y segregación de funciones.³⁴³⁵³⁶³⁷

Indicadores:

- Porcentaje de controles clave automatizados (por ejemplo, bloqueo de cuentas tras múltiples intentos, despliegue de parches, políticas de MFA).
- Porcentaje de procesos críticos con controles preventivos frente a controles detectivos/correctivos.
- Número de excepciones de control aprobadas formalmente y revisadas periódicamente.

30 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

31 <https://www.konfirmity.com/blog/soc-2-what-changed-in-2026>

32 <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

33 <https://www.flexxible.com/en/blog/nis2-directive-spain>

34 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

35 <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

36 <https://secureframe.com/hub/soc-2/trust-services-criteria>

37 <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

Pregunta:

- “Indique qué tan industrializados están sus controles de seguridad:
A) Artesanía manual exquisita.
B) Semi-automatizados y a veces sincronizados.
C) Orquestación sistemática con evidencias y reportes.”
- A) Artesanía manual exquisita.
- B) Semi-automatizados y a veces sincronizados.
- C) Orquestación sistemática con evidencias y reportes.”

2.6 CC6 – Controles de acceso lógico y físico

En 2025–2026, los reportes SOC 2 suelen mostrar un giro hacia modelos Zero Trust, MFA universal, segmentación avanzada y controles dinámicos basados en riesgo.³⁸³⁹⁴⁰⁴¹

Indicadores habituales:

- Porcentaje de cuentas con MFA activado por tipo (empleados, terceros, cuentas privilegiadas, acceso remoto).
- Ratio de cuentas de servicio/documentadas vs. huérfanas detectadas en revisiones periódicas.
- Porcentaje de sistemas críticos segmentados en redes aisladas con filtrado de tráfico basado en identidad y contexto.

Pregunta:

- “En el control de accesos, su organización se considera más cercana a:
A) El castillo medieval con puente levadizo.
B) El aeropuerto con controles por zonas.
C) La nave espacial Zero Trust con decisiones continuas de acceso.”
- A) El castillo medieval con puente levadizo.
- B) El aeropuerto con controles por zonas.
- C) La nave espacial Zero Trust con decisiones continuas de acceso.”

38 <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

39 <https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2>

40 <https://www.flexxible.com/en/blog/nis2-directive-spain>

41 <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

2.7 CC7 – Operaciones del sistema

SOC 2 exige evidencia de monitorización de operaciones, gestión de vulnerabilidades, capacidad de reacción y continuidad técnica.⁴²⁴³⁴⁴⁴⁵

Indicadores:

- Porcentaje de sistemas críticos con parches de seguridad aplicados dentro de SLA (ej. 7/30/90 días según criticidad).
- Número de vulnerabilidades críticas abiertas por encima de SLA.
- Porcentaje de incidentes clasificados correctamente por severidad en $\leq X$ horas.

Pregunta:

- “¿La gestión de parches en su organización se parece más a un ciclo regular o a un festival anual de ‘parcheo heroico’?”

2.8 CC8 – Gestión de cambios

La expectativa es de trazabilidad completa de cambios, pruebas, aprobaciones y rollback, especialmente en entornos CI/CD y cloud.⁴⁶⁴⁷⁴⁸⁴⁹

Indicadores:

- Porcentaje de cambios en producción documentados y aprobados formalmente (especial atención a cambios de emergencia).
- Ratio de incidencias en producción atribuibles a cambios no autorizados o insuficientemente probados.
- Porcentaje de pipelines CI/CD con controles de seguridad integrados (SAST, DAST, control de dependencias, firmas de artefactos).

Pregunta:

42 <https://linfordco.com/blog/trust-services-criteria-principles-soc-2/>

43 <https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2>

44 <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

45 <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

46 <https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2>

47 <https://secureframe.com/hub/soc-2/trust-services-criteria>

48 <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

49 <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

- “En su organización, ¿los cambios urgentes siguen algún procedimiento reconocible por seres humanos o son un arte oscuro practicado a medianoche?”

2.9 CC9 – Mitigación de riesgos

Aquí se observa la madurez real: se mide si los riesgos identificados terminan en acciones, no en diapositivas.⁵⁰⁵¹⁵²

Indicadores:

- Porcentaje de riesgos críticos y altos con medidas de mitigación completadas dentro del plazo comprometido.
- Porcentaje de hojas de ruta de seguridad ejecutadas según cronograma (presupuesto, proyecto, beneficios logrados).
- Porcentaje de lecciones aprendidas de incidentes que se traducen en cambios de control medibles.

Pregunta:

- “Cuando documentan lecciones aprendidas, ¿se convierten en acciones verificables o en una elegante literatura que admiran en el próximo comité?”

3. Otros criterios SOC 2: disponibilidad, integridad, confidencialidad, privacidad

3.1 Disponibilidad

Enfocado en que los sistemas estén disponibles según acuerdos y requisitos, muy alineado con ENS (dimensión disponibilidad) y NIS2 (continuidad de servicios esenciales).⁵³⁵⁴⁵⁵⁵⁶⁵⁷

Indicadores frecuentes:

50 <https://secureframe.com/hub/soc-2/trust-services-criteria>

51 <https://www.konfirmity.com/blog/soc-2-what-changed-in-2026>

52 <https://secureframe.com/hub/soc-2/trust-services-criteria>

53 <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

54 <https://www.konfirmity.com/blog/soc-2-what-changed-in-2026>

55 <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

56 <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

57 <https://www.flexxible.com/en/blog/nis2-directive-spain>

- Tiempo de inactividad no planificado de servicios críticos (por mes/año) vs. SLA.
- Porcentaje de pruebas satisfactorias de planes de continuidad de negocio y recuperación ante desastres (BCP/DRP), incluyendo ejercicios de mesa y simulacros técnicos.¹²¹³
- Porcentaje de servicios críticos cubiertos por arquitecturas de alta disponibilidad y redundancia geográfica.

Pregunta:

- “¿Su plan de continuidad se ha probado en los últimos 12 meses con algo más que una reunión y café, es decir, con simulacros que hayan roto algo (controladamente)?”

3.2 Integridad del procesamiento

Busca asegurar que el procesamiento de datos es completo, preciso, autorizado y oportuno.⁵⁸⁵⁹⁶⁰

Indicadores:

- Porcentaje de transacciones procesadas con controles de validación y reconciliación automatizados.
- Número de incidentes significativos de errores de procesamiento detectados tras la entrega al cliente.
- Tiempo medio para detectar y corregir errores de procesamiento críticos.

Pregunta:

- “¿Cuántas veces al año confían en que ‘el sistema nunca se equivoca’ sin un mecanismo independiente que lo verifique?”

3.3 Confidencialidad

Muy vinculado a cifrado, clasificación de información y controles de acceso, y en Europa inevitablemente casado con RGPD y ENS.⁶¹⁶²⁶³⁶⁴

Indicadores:

⁵⁸ <https://linfordco.com/blog/trust-services-criteria-principles-soc-2/>

⁵⁹ <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

⁶⁰ <https://secureframe.com/hub/soc-2/trust-services-criteria>

⁶¹ <https://linfordco.com/blog/trust-services-criteria-principles-soc-2/>

⁶² <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

⁶³ <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

⁶⁴ <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

- Porcentaje de datos clasificados bajo categorías corporativas (público, interno, confidencial, restringido) y cubiertos por controles acordes.
- Porcentaje de datos confidenciales y personales cifrados en reposo y en tránsito.
- Número de incidentes de divulgación no autorizada (incluidos near misses) por periodo.

Pregunta:

- “¿La clasificación de la información vive en un excel olvidado o condiciona realmente quién ve qué y dónde?”

3.4 Privacidad

SOC 2 utiliza criterios de privacidad alineados con AICPA y, en Europa, los auditores miran de reojo al RGPD: transparencia, minimización, derechos de interesados, transferencias internacionales.⁶⁵⁶⁶⁶⁷

Indicadores:

- Porcentaje de tratamientos de datos personales con evaluación de impacto (DPIA) cuando procede.
- Tiempo medio de respuesta a solicitudes de derechos de los interesados (acceso, rectificación, supresión, etc.).
- Porcentaje de proveedores con acceso a datos personales cubiertos por contratos y garantías adecuadas (incluidos mecanismos de transferencias internacionales).

Pregunta:

- “Cuando un ciudadano ejerce su derecho de acceso, ¿su organización responde con solvencia jurídica o con una expedición arqueológica por sistemas heredados?”

4. España: SOC 2 como “lengua franca” frente a ENS, RGPD y NIS2

Aunque SOC 2 es un marco AICPA de origen estadounidense, se ha convertido en referencia internacional y se usa en España como prueba de madurez de controles frente a marcos regulatorios locales (ENS, RGPD, NIS2, sectoriales), especialmente para servicios cloud y proveedores críticos.⁶⁸⁶⁹⁷⁰⁷¹

⁶⁵ <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

⁶⁶ <https://macpas.com/are-new-aicpa-soc-2-criteria-updates-on-the-horizon/>

⁶⁷ <https://www.brightdefense.com/resources/soc-2-trust-services-criteria/>

⁶⁸ <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

⁶⁹ <https://www.konfirmity.com/blog/soc-2-what-changed-in-2026>

⁷⁰ <https://www.flexxible.com/en/blog/nis2-directive-spain>

⁷¹ <https://www.cbh.com/insights/articles/soc-2-trust-services-criteria-guide/>

4.1 ENS (Esquema Nacional de Seguridad)

ENS establece principios y requisitos de seguridad para el sector público español y proveedores que manejan información o servicios públicos, con niveles Básico, Medio y Alto.⁷²⁷³⁷⁴

Convergencias clave para indicadores SOC 2 a nivel nacional:

- Dimensiones ENS (disponibilidad, autenticidad, integridad, confidencialidad, trazabilidad) mapean bien a los TSC de SOC 2.¹³¹⁵⁴
- Controles ENS sobre gestión de activos, control de accesos, explotación, continuidad y monitorización son equivalentes conceptuales a CC1–CC9 y a los criterios de disponibilidad e integridad.¹³⁴

Para una encuesta nacional, tener un anexo de mapeo ENS ↔ SOC 2 permitiría preguntar en “idioma SOC 2” a operadores que piensan en ENS.

4.2 NIS2 y futura ley española de ciberseguridad

España está culminando la transposición de NIS2 mediante una ley que fusiona NIS2 con la Directiva de Resiliencia de Entidades Críticas, creando el Centro Nacional de Ciberseguridad (CNCS) como autoridad de supervisión.⁷⁵⁷⁶⁷⁷

Esta normativa exige:

- Gobernanza de ciberseguridad con responsabilidad clara de altos directivos, medidas técnicas y organizativas, y gestión de incidentes reportables en plazos estrictos.⁴⁵
- Capacidad de supervisión y auditoría fuerte por CNCS, con sanciones relevantes.⁴

En términos SOC 2, esto se traduce en:

- Reforzar métricas de CC1–CC4 (gobierno, riesgo, monitorización) con indicadores de incident management, reporting y resiliencia operacional.
- Pedir expresamente métricas sobre incidentes reportados a autoridades, cumplimiento de plazos, y lecciones aprendidas integradas en el marco de control.

Pregunta tipo NIS2-friendly:

⁷² <https://www.schellman.com/blog/latest-soc-2-guidance-revisions-october-2022>

⁷³ <https://continuumgrc.com/es/an-in-depth-guide-to-soc-2-security-common-criteria/>

⁷⁴ <https://www.flexxible.com/en/blog/nis2-directive-spain>

⁷⁵ <https://www.konfirmity.com/blog/soc-2-what-changed-in-2026>

⁷⁶ <https://www.irm360.eu/es/normen-es/soc2/>

⁷⁷ <https://www.kiteworks.com/es/cumplimiento-regulatorio/soc-2-report/>

- “Indique el porcentaje de incidentes significativos que han sido notificados dentro de los plazos reglamentarios (NIS2/ENS/RGPD), y el porcentaje en que esa notificación se basó en detección automatizada frente a descubrimiento casual.”

5. Propuesta de indicadores para encuesta SOC 2 “España 2026”

5.1 Tabla de ejes principales

Tabla orientada a un cuestionario nacional (respuestas numéricas y cualitativas), alineada con SOC 2, ENS y NIS2.

Eje SOC 2 / ENS	Indicador sugerido	Comentario de madurez
CC1 - Gobernanza	% de servicios críticos con objetivos de seguridad aprobados por órgano de gobierno	Alinea SOC 2 con gobernanza NIS2.245
CC2 - Comunicación	Frecuencia de reporting de ciberseguridad a la alta dirección (mensual, trimestral, ad hoc)	Refuerza cultura y responsabilidad.910
CC3 - Riesgos	% de activos críticos con análisis de riesgos actualizado ≤ 12 meses	Clave para ENS Alto y NIS2.4515
CC4 - Monitorización	MTTD/MTTR para incidentes críticos y % de sistemas bajo monitorización continua	Conecta con requisitos de detección temprana.64
CC5 - Control	% de controles clave automatizados y documentados	Mide industrialización del control.28
CC6 - Accesos	Cobertura MFA por tipo de cuenta, ratio de cuentas huérfanas	Indicador clásico de Zero Trust.629
CC7 - Operaciones	% de vulnerabilidades críticas dentro de SLA y nº fuera de plazo	Mide disciplina de parcheo.116
CC8 - Cambios	% de cambios en producción aprobados y trazables, % de pipelines con controles de seguridad	Crucial en entornos CI/CD cloud.28
CC9 - Mitigación	% de riesgos críticos con plan ejecutado en plazo, nº de lecciones aprendidas implementadas	Es la métrica de “de las palabras a los hechos”.910
Disponibilidad	Horas de caída no planificada vs. SLA, nº de pruebas BCP/DRP al año	Relevante para servicios esenciales.131
Integridad	Nº de incidentes por errores de procesamiento y tiempo de corrección	Afecta confianza y cumplimiento.12
Confidencialidad	% de datos confidenciales cifrados en reposo/tránsito, nº de fugas	Conecta con ENS y RGPD.1413
Privacidad	Tiempo medio de respuesta a derechos de interesados, % de tratamientos con DPIA	Enfoque europeo claro.16

5.2 Estilo de preguntas para encuesta nacional

Algunos ejemplos de formulación, en clave ágil pero rigurosa:

- “Indique el porcentaje aproximado de sus activos y servicios clasificados como críticos que cuentan con un análisis de riesgo formal realizado o actualizado en los últimos 12 meses (sí, 2019 ya no cuenta).”
- “¿Cuenta su organización con un Centro de Operaciones de Seguridad (propio o externo) que monitoriza, como mínimo, los sistemas clasificados como esenciales según ENS/NIS2? En caso afirmativo, indique el porcentaje estimado de dichos sistemas bajo monitorización efectiva.”
- “Para el último año, seleccione el intervalo que mejor represente su tiempo medio de detección de incidentes de severidad alta (MTTD):
 - A) Más de 1 semana.
 - B) Entre 24 horas y 1 semana.
 - C) Entre 1 y 24 horas.
 - D) Menos de 1 hora (sí, puede presumir un poco).”
- “En relación con las solicitudes de derechos de los interesados (RGPD), indique el porcentaje aproximado satisfecha dentro de los plazos legales, y señale si dispone de registros y métricas para demostrarlo ante una autoridad.”
- A) Más de 1 semana.
- B) Entre 24 horas y 1 semana.
- C) Entre 1 y 24 horas.
- D) Menos de 1 hora (sí, puede presumir un poco).”

6. Mirando al 2027: IA, automatización y auditoría

La comunidad de auditores SOC 2 habla ya de incorporar de forma más explícita la gestión de riesgos de IA, automatización de controles y dependencia de terceros críticos, aunque los criterios formales aún no han cambiado desde 2017 (solo su guía y puntos de enfoque en 2022).⁷⁸⁷⁹⁸⁰⁸¹

Esto se está traduciendo, en la práctica, en indicadores nuevos que podrías incorporar ya en una encuesta avanzada:

⁷⁸ <https://www.brightdefense.com/resources/soc-2-trust-services-criteria/>

⁷⁹ <https://www.defendsphere.io/post/beyond-ens-why-nis2-is-the-new-imperative-for-spanish-healthcare-how-to-prepare>

⁸⁰ <https://scytale.ai/center/soc-2/the-latest-soc-2-revisions-and-what-they-mean-for-your-business/>

⁸¹ <https://community.trustcloud.ai/docs/grc-launchpad/grc-101/compliance/getting-started-with-soc-2-trust-service-criteria-selection-guide/>

- Porcentaje de decisiones críticas automatizadas (incluyendo IA) con evaluaciones de riesgo y controles de explicabilidad/transparencia.
- Número y criticidad de proveedores cloud y SaaS sometidos a due diligence basada en informes SOC 2 y otros esquemas (ISO 27001, ENS, etc.), incluyendo la revisión efectiva de esos informes.¹⁸¹³
- Porcentaje de controles de seguridad monitorizados por herramientas de continuous compliance (GRC, CSPM, CIEM, etc.), con evidencias generadas y conservadas automáticamente.¹⁷¹⁶

Pregunta sugerida:

- “En el ámbito de IA y automatización, ¿hasta qué punto su organización ha establecido controles formales (evaluaciones de impacto, límites de uso, monitorización) o sigue confiando en la fe tecnológica?”

192021222324252627282930